

Guía metodológica para la encuesta de ciberseguridad, continuidad de negocio y ciber-resiliencia

Esta guía explica **cómo aplicar, puntuar e interpretar** la encuesta propuesta en encuesta-modelo.md, así como su conexión con el cálculo de índices de madurez (IMD) e Índice Global de Madurez (IGM).

1. Objetivos de la encuesta

La encuesta persigue tres objetivos principales:

1. Medir de forma estructurada el nivel de madurez de la organización en:
2. Gobierno y estrategia de ciberseguridad/BCM.
3. Gestión de riesgos, vulnerabilidades y pruebas técnicas (pentesting).
4. Monitorización y respuesta (SIEM, gestión de incidentes).
5. Continuidad de negocio y recuperación (BCM/DRP).
6. Capacitación, cultura y métricas.
7. Proveedores y ecosistema.
8. Identificar brechas frente a marcos normativos y de buenas prácticas (ENS, NIS2, DORA, ISO 27001, ISO 22301...).
9. Proporcionar una base cuantitativa y cualitativa para:
10. Priorizar iniciativas de mejora.
11. Argumentar necesidades de inversión.
12. Realizar seguimiento en el tiempo.

Proveedores y ecosistema.

Identificar **brechas frente a marcos normativos y de buenas prácticas** (ENS, NIS2, DORA, ISO 27001, ISO 22301...).

Proporcionar una base cuantitativa y cualitativa para:

2. Alcance y unidad de análisis

2.1. ¿A quién se aplica?

La unidad de análisis puede ser:

- Una organización completa.
- Una unidad de negocio o área (por ejemplo, un hospital, una consejería, una línea de negocio).
- Un conjunto de organizaciones (diagnóstico sectorial o territorial).

Es importante definir el alcance antes de comenzar y reflejarlo de forma clara en la documentación y en los metadatos (por ejemplo, en Datos_Respuestas).

2.2. ¿Quién responde?

Idealmente, la encuesta la responden **equipos multidisciplinares** formados por:

- Responsables de ciberseguridad y TI.
- Responsables de continuidad de negocio, riesgos y cumplimiento.
- Representantes del negocio/operación.

Se recomienda que la respuesta **no sea individual**, sino fruto de un **consenso razonado** entre quienes conocen el funcionamiento real de los procesos.

3. Escalas de respuesta y codificación

3.1. Escala principal de madurez (Likert 4 niveles)

La mayoría de las preguntas utilizan una escala de 4 opciones (a-d) que se codifica numéricamente de la siguiente forma:

- a) Situación muy incipiente → 0
- b) Situación básica → 1
- c) Situación intermedia → 2
- d) Situación avanzada/madura → 3

Este esquema evita el «punto medio cómodo» y fomenta tomar partido.

3.2. Preguntas de perfil

Las preguntas de perfil (ORG-01 a ORG-05) no generan directamente puntuaciones de madurez, pero sí permiten:

- Segmentar resultados por tipo de organización, tamaño, sector...
- Contextualizar el IGM y los IMD.

3.3. Comentarios cualitativos

Se recomienda añadir, en la herramienta que se utilice (formulario online o plantilla), campos de **comentarios libres** por bloque. Estos no se codifican numéricamente, pero son esenciales para interpretar matices y particularidades.

4. Dominios y códigos de preguntas

Los códigos de pregunta siguen una estructura que facilita el análisis posterior:

- ORG-xx: Perfil de la organización.
- GOV-xx: Gobierno y estrategia.
- RISK-xx: Gestión de riesgos.
- VULN-xx: Gestión de vulnerabilidades.
- PENT-xx: Pruebas de penetración.
- SIEM-xx: Monitorización y eventos de seguridad.
- BCM-xx: Continuidad de negocio.
- DRP-xx: Recuperación de TI.
- AWARE-xx: Capacitación y cultura.
- MET-xx: Métricas y KPIs.
- ROI-xx: ROI y valor percibido.
- SUP-xx: Proveedores y terceros.
- ECO-xx: Ecosistema y coordinación externa.

Estos códigos se usan en:

- encuesta-modelo.md (texto de la encuesta).
- mapeo-normas.md (relación con marcos normativos).
- plantilla-igm-roi.md (diccionario de preguntas y cálculo de índices).

5. Proceso de aplicación

5.1. Fases

13. Preparación
14. Definir alcance, lista de organizaciones/unidades y cronograma.
15. Seleccionar participantes clave por organización.
16.
Ajustar, si es necesario, el texto de algunas preguntas para adaptarlas al contexto.
17.
Comunicación
18.
Usar la narrativa de narrativa-exp.md para:

Informar a la alta dirección y solicitar patrocinio.
Invitar a los equipos técnicos a participar.
19.
Realización de sesiones de respuesta
20. Modalidad recomendada:
Sesiones de 60–90 minutos con los equipos clave.
El facilitador lee cada pregunta, se discute brevemente y se acuerda la opción a marcar.
21.
Alternativamente, se puede usar autoevaluación individual seguida de una sesión de consolidación.
22.
Consolidación y validación
23. Revisar coherencia de respuestas.
24.
Aclarar divergencias significativas en preguntas críticas.
25.
Carga de datos y cálculo de índices
26. Registrar respuestas en la hoja Datos_Respuestas.

27.

Verificar que las fórmulas de `Calculos_Madurez` y `ROI_Costes_Beneficios` funcionan.

28.

Análisis y preparación de informe

29. Analizar IMD e IGM.

30. Revisar mapeo normativo (brechas frente a ENS, NIS2, DORA, etc.).

31. Construir reporte ejecutivo (`ppt-report.md`).

Ajustar, si es necesario, el texto de algunas preguntas para adaptarlas al contexto.

Comunicación

Usar la narrativa de `narrativa-exp.md` para:

- Informar a la alta dirección y solicitar patrocinio.
- Invitar a los equipos técnicos a participar.

Realización de sesiones de respuesta

- Sesiones de 60–90 minutos con los equipos clave.
- El facilitador lee cada pregunta, se discute brevemente y se acuerda la opción a marcar.

Alternativamente, se puede usar autoevaluación individual seguida de una sesión de consolidación.

Consolidación y validación

Aclarar divergencias significativas en preguntas críticas.

Carga de datos y cálculo de índices

Verificar que las fórmulas de `Calculos_Madurez` y `ROI_Costes_Beneficios` funcionan.

Análisis y preparación de informe

5.2. Rol del facilitador

Es clave contar con una persona que:

- Conozca bien la encuesta y la guía.
- Mantenga la discusión en un tono constructivo, pragmático y, si hace falta, ligeramente irónico para relajar el ambiente.
- Ayude a traducir ejemplos concretos de los equipos a las opciones de respuesta disponibles.

6. Cálculo de índices de madurez

El detalle técnico está en `plantilla-igm-roi.md`. Aquí se resumen los conceptos clave.

6.1. Índices de Madurez por Dominio (IMD)

Para cada dominio (GOV, RISK, VULN, PENT, SIEM, BCM, DRP, AWARE, MET, ROI, SUP, ECO):

- Se calcula la media (o media ponderada) de las respuestas numéricas de las preguntas de ese dominio.
- El resultado se expresa en la escala 0–3 y, opcionalmente, se normaliza a 0–100.

Ejemplo de interpretación (escala 0–3):

- 0,0–0,9 – Nivel «incipiente».
- 1,0–1,9 – Nivel «básico».
- 2,0–2,5 – Nivel «intermedio».
- 2,6–3,0 – Nivel «avanzado».

Los umbrales pueden adaptarse según el apetito de exigencia de la organización.

6.2. Índice Global de Madurez (IGM)

- Puede construirse como media simple de los IMD.
- O como media ponderada (por ejemplo, dando más peso a dominios críticos como BCM, SIEM o RISK).

La interpretación es análoga a la de los IMD, pero a nivel global.

7. Uso del mapeo normativo

El archivo mapeo-normas.md permite relacionar:

- Cada pregunta con uno o varios marcos normativos.
- El tipo de requisito (obligatorio o recomendado).

Recomendaciones de uso:

- Para preguntas con bajas puntuaciones y mapeo a requisitos obligatorios:
- Priorizar acciones para evitar brechas de cumplimiento.
- Para preguntas con bajas puntuaciones pero mapeo a buenas prácticas:
- Evaluar la relación coste-beneficio de mejorar, especialmente si el impacto en resiliencia es alto.

Esto ayuda a traducir los resultados de la encuesta al lenguaje de **riesgo regulatorio** además del riesgo operativo.

8. Interpretación cualitativa y storytelling

Los números son necesarios, pero insuficientes. Se recomienda:

- Revisar conjuntamente IMD e IGM junto con comentarios cualitativos recogidos durante las sesiones.
- Identificar «patrones narrativos»:
- Por ejemplo: buena tecnología (SIEM, pentesting) pero débil gobernanza o cultura.
- O: sólidos BCP en papel, pero escasa práctica de ejercicios.
- Construir un relato honesto sobre:
- Lo que ya se hace bien (para reforzarlo y reconocerlo).
- Lo que hay que mejorar (sin dramatismos, pero con claridad).

La plantilla ppt - reporte .md está pensada precisamente para articular ese relato.

9. Frecuencia de repetición y seguimiento

- Recomendación mínima: repetir la encuesta una vez al año.
- En contextos muy dinámicos o bajo fuerte presión regulatoria, puede repetirse cada 6 meses con un enfoque más ligero.
- Es importante mantener:
- La trazabilidad de versiones del cuestionario.
- La comparabilidad de escalas para poder analizar tendencias.

10. Limitaciones y advertencias

- La encuesta es un instrumento de autoevaluación: refleja percepciones informadas, pero no sustituye auditorías técnicas ni revisiones independientes.
- Las puntuaciones deben interpretarse relativamente (comparando dominios y evolución en el tiempo), no como verdades absolutas.
- Las estimaciones de ROI son aproximadas y dependen de la calidad de las hipótesis sobre pérdidas evitadas.

Bien aplicada, la encuesta puede convertirse en un **termómetro recurrente de ciber-resiliencia**, útil tanto para los equipos técnicos como para los órganos de gobierno. Como todo buen termómetro, no cura por sí mismo, pero ayuda a decidir cuándo hace falta algo más que una manta y un vaso de agua caliente.